

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA51 COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 10%

QUESTIONS: 20 TOTAL MARKS: 20 Annexure A
MOCK INTERVIEW

Code of Conduct:

I P.Paneendra (192321072) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:P.Paneendra

Annexure A

MOCK INTERVIEW

1. Analyze the weaknesses of SSL and explain why TLS is considered more secure in modern web systems.
2. Apply the TLS handshake process to explain how secure session keys are established between a client and server.
3. Compare SSL and TLS in terms of encryption mechanisms and identify key improvements in TLS.
4. Evaluate a scenario where improper certificate validation in TLS leads to a security breach. What could go wrong?
5. Analyze the role of digital certificates in SSL/TLS and explain how they ensure authentication.
6. Apply your understanding of SET protocol to explain how it protects credit card transactions in e-commerce.
7. Evaluate the limitations of the SET protocol in current online payment systems.
8. Compare SET protocol with TLS-based payment security and justify which is more practical today.
9. Analyze a malware attack scenario and differentiate whether it is caused by a virus, worm, or Trojan.
10. Apply appropriate mitigation techniques for a worm attack spreading across a corporate network.
11. Evaluate the impact of Trojan attacks on system confidentiality and integrity with an example scenario.
12. Compare viruses, worms, and Trojans based on propagation method and system impact.
13. Analyze the working of a packet-filtering firewall and identify its limitations in modern networks.
14. Apply firewall rules to block unauthorized access while allowing legitimate traffic in a given scenario.

15. Evaluate the effectiveness of stateful inspection firewalls over stateless firewalls.
16. Compare different types of firewalls and recommend the most suitable one for an enterprise network.
17. Analyze how an IDS detects malicious activities using signature-based and anomaly-based techniques.
18. Apply IDS/IPS mechanisms to prevent a distributed denial-of-service (DDoS) attack.
19. Evaluate the differences between IDS and IPS in terms of response to detected threats.
20. Propose improvements to reduce false positives in an IDS while maintaining high detection accuracy.

ANSWER

1. Weaknesses of SSL and why TLS is more secure

SSL is an older security protocol and has several weaknesses. SSL 2.0 and SSL 3.0 have known security vulnerabilities, weak cryptographic algorithms, and poor protection against certain attacks such as POODLE. SSL also has limitations in its handshake and cipher-suite design. TLS was introduced as a stronger replacement. Modern TLS versions, especially TLS 1.2 and TLS 1.3, provide stronger encryption, better authentication, improved handshake security, and removal of outdated algorithms. Therefore, modern web systems use TLS instead of SSL.

2. TLS handshake and establishment of session keys

The TLS handshake establishes a secure connection between the client and server.

1. The client sends a **ClientHello** containing supported TLS versions, cipher suites, and a

random value.

2. The server responds with **ServerHello** and selects the security parameters.
3. The server sends its **digital certificate** to prove its identity.
4. The client validates the certificate.
5. Using a key-exchange mechanism such as Diffie-Hellman, both sides establish shared key material.
6. Session keys are derived from this shared secret.
7. Both sides confirm that the handshake was successful.
8. The session keys are then used to encrypt and authenticate application data.

Thus, the actual data is protected using symmetric session keys, which are much faster than public-key encryption.

3. SSL vs TLS: encryption mechanisms and improvements

SSL and TLS both use a combination of asymmetric and symmetric cryptography. Asymmetric cryptography is mainly used during authentication and key establishment, while symmetric encryption protects the actual communication.

TLS improves upon SSL through stronger cipher suites, better key derivation, improved authentication, stronger integrity protection, and removal of insecure algorithms. TLS 1.3 further simplifies the handshake, removes obsolete cryptographic options, and provides stronger default security.

4. Improper certificate validation and security breach

Suppose a user connects to an online banking website, but the application does not properly validate the server's certificate. An attacker could present a fraudulent certificate and act as a **man-in-the-middle**.

The user may believe the connection is secure while actually communicating with the attacker. The attacker could capture login credentials, modify transactions, or steal sensitive information. Therefore, certificate validation must check the certificate chain, hostname, validity period, and

trust status.

5. Role of digital certificates in SSL/TLS

A digital certificate connects a server's identity with its public key. It is issued and digitally signed by a trusted Certificate Authority (CA).

During TLS authentication, the server sends its certificate to the client. The client verifies that the certificate is trusted, valid, belongs to the requested domain, and has not expired or been revoked. If validation succeeds, the client can trust that it is communicating with the intended server.

6. How SET protects credit-card transactions

SET (Secure Electronic Transaction) was designed specifically for secure credit-card payments over the Internet.

It uses digital certificates to authenticate customers and merchants. It also uses encryption to protect payment information. A major feature is that the customer's payment information can be protected so that the merchant does not directly see sensitive card details.

SET uses digital signatures and encryption to provide **authentication, confidentiality, integrity, and non-repudiation**. This makes unauthorized modification or interception of payment information much more difficult.

7. Limitations of SET today

SET has several limitations:

- It is complex to implement.
- It requires digital certificates for participants.
- Certificate management can be difficult.
- It requires additional infrastructure.
- It increases transaction complexity.
- Users and merchants may find it difficult to deploy.

- Modern payment systems have simpler approaches.

Because of these limitations, SET is rarely used in modern online payment systems.

8. SET vs TLS-based payment security

SET provides security specifically for payment transactions using certificates and digital signatures, but it is complex and requires additional infrastructure.

TLS is more general-purpose. It creates a secure channel between the user's browser and the website and protects information such as login credentials and payment details during transmission.

TLS is more practical today because it is widely supported, easier to deploy, faster, and already integrated into modern browsers, servers, and payment systems.

9. Malware scenario: virus, worm, or Trojan

Consider a situation where an employee downloads a seemingly useful software application. After installation, the program secretly steals files and passwords.

This is a **Trojan** because the malware is disguised as legitimate software and depends on the user executing it.

A **virus** normally attaches itself to legitimate files and spreads when infected files are executed.

A **worm** can automatically spread across networks without requiring users to manually execute an infected file.

10. Mitigation techniques for a worm attack

For a worm spreading through a corporate network, the organization should:

- Isolate infected systems immediately.
- Block malicious network traffic.
- Patch vulnerable operating systems and applications.
- Update antivirus and endpoint security software.

- Use firewalls to restrict unnecessary connections.
- Segment the corporate network.
- Monitor network traffic for unusual behavior.
- Remove the malware from infected systems.
- Change compromised credentials.
- Restore affected systems if necessary.

Network segmentation is especially useful because it prevents the worm from easily reaching the entire organization.

11. Impact of Trojan attacks on confidentiality and integrity

A Trojan can seriously affect both confidentiality and integrity.

For example, an employee downloads a fake accounting application. The application appears normal but secretly records usernames and passwords and sends them to an attacker. This violates **confidentiality**.

If the Trojan also modifies financial records or system files, it affects **integrity**. Therefore, Trojans can allow attackers to steal information, modify data, install additional malware, or gain unauthorized access.

12. Viruses, worms, and Trojans

A **virus** attaches itself to another file or program and usually spreads when the infected file is executed. It can corrupt files, modify data, or damage systems.

A **worm** is a self-replicating malware that can spread automatically through networks. It can consume network bandwidth and infect many systems quickly.

A **Trojan** disguises itself as legitimate software and tricks the user into installing or running it. It can steal information, provide unauthorized access, or install other malware.

The main difference is their **propagation method**: viruses depend on infected files, worms spread automatically, and Trojans depend mainly on deception.

13. Packet-filtering firewall and its limitations

A packet-filtering firewall examines network packets and checks fields such as:

- Source IP address
- Destination IP address
- Source port
- Destination port
- Protocol

Based on predefined rules, the firewall either allows or blocks the packet.

For example, a rule may allow HTTP/HTTPS traffic while blocking unauthorized ports.

However, packet-filtering firewalls generally do not understand the full application context. Basic stateless filtering does not track connection state and may have difficulty detecting sophisticated application-level attacks, encrypted threats, or malicious traffic that appears legitimate.

14. Applying firewall rules

Suppose a company has a web server that should accept HTTPS traffic from the Internet but should not allow direct access to its database.

Rules could be:

1. Allow TCP traffic to port **443** for the web server.
2. Allow required internal administrative traffic.
3. Block Internet access to the database port.
4. Block unnecessary incoming ports.
5. Allow established and legitimate responses.
6. Deny all other unauthorized incoming traffic.

This follows the principle of **least privilege**, where only required traffic is permitted.

15. Stateful vs stateless firewalls

A **stateless firewall** evaluates each packet independently according to predefined rules. It does not remember previous packets.

A **stateful firewall** maintains information about active connections. It can determine whether a packet belongs to an established and legitimate connection.

Stateful firewalls are generally more effective because they understand connection context and can automatically allow valid response traffic while blocking unexpected packets. However, they require more processing and memory than simple stateless filtering.

16. Types of firewalls and suitable enterprise firewall

Common firewall types include:

- Packet-filtering firewall
- Stateful inspection firewall
- Proxy/application firewall
- Circuit-level gateway
- Next-generation firewall (NGFW)

For a modern enterprise, a **Next-Generation Firewall** is generally the most suitable. It can combine stateful inspection with application awareness, intrusion prevention, user-based controls, and other security features.

It provides better protection against modern threats than a basic packet-filtering firewall.

17. Signature-based and anomaly-based IDS

An **Intrusion Detection System (IDS)** monitors network or system activity and identifies suspicious behavior.

Signature-based detection compares activity against known attack patterns. For example, if network traffic matches the signature of a known malware attack, the IDS generates an alert. It is accurate for known threats but may not detect new attacks.

Anomaly-based detection establishes a normal behavior pattern and identifies significant deviations. It can detect previously unknown attacks but may produce more false positives.

Using both methods provides better overall detection.

18. IDS/IPS against DDoS attacks

During a DDoS attack, attackers send a very large amount of traffic toward a target.

An IDS can monitor traffic and detect unusual increases in traffic volume, repeated requests, or suspicious patterns. It generates alerts for administrators.

An IPS can actively block or limit malicious traffic. Protection can also include:

- Rate limiting
- Traffic filtering
- Blocking malicious IP addresses
- Network segmentation
- Load balancing
- DDoS protection services

For large-scale DDoS attacks, dedicated upstream or cloud-based DDoS protection is often required because the attack may overwhelm the network before local security devices can stop it.

19. IDS vs IPS

An **IDS** mainly detects and reports suspicious activity. It is generally placed in a monitoring role and does not directly block the traffic.

An **IPS** detects suspicious activity and can automatically take action, such as dropping packets, blocking traffic, or terminating connections.

Therefore, IDS is mainly focused on **detection and alerting**, while IPS provides **detection and prevention**.

20. Reducing false positives in IDS

False positives occur when legitimate activity is incorrectly identified as an attack.

To reduce them while maintaining detection accuracy, an organization can:

- Tune detection rules.
- Update attack signatures regularly.
- Establish accurate normal-behavior baselines.
- Whitelist trusted systems where appropriate.
- Use multiple detection techniques.
- Apply context-aware analysis.
- Use machine-learning techniques carefully.
- Correlate alerts from multiple security sources.
- Continuously monitor and adjust rules.

The goal is to find the right balance between **high detection accuracy and a manageable number of false alarms**.